

Anomaly Detection in Support of Adaptive Access Control

Angela Helvin

Department of Computer Science

University of York

York, United Kingdom

alh624@york.ac.uk

Abstract—Anomaly detection can be used within access controlled environments to detect unusual activity from within, monitoring access and flagging deviations from expected behaviour in real time. Where such deviations can be identified, there is the potential to adjust the access control rules, to demote user access control permissions, in order to protect systems from accidental or malicious insider threats. We extend recent research on extending role-based access control (RBAC) with self-adaption capabilities by looking at anomaly detection in the context of identification of statistical outliers. Several statistical techniques for anomaly detection, new to this research area, were identified and integrated into a self-adaptive RBAC approach: Z-Scores, Tukey’s Interquartile Range method, Cluster Analysis, and Analysis of Variance, together with statistical hypothesis testing to detect differences in user behaviour from some observed norm. The new self-adaptive RBAC method that uses these techniques was evaluated using a simulated version of a business process from a real company. The methods applied were able to successfully detect unusual behaviour from data captured in log files, demonstrating the usefulness of statistical techniques for anomaly detection purposes, and in informing self-adaption policies for use in access controlled environments.

1. INTRODUCTION

Insider threats arise when authorised users of a system misuse their privileges to negatively impact the organisation. Insider threat has potential to cause severe damage to an organisation and whilst work has been done to detect insiders at the system level (e.g. via intrusion detection systems [1], [2]) access control mechanisms such as the widely-implemented Role Based Access Control (RBAC) [3] are unable to adapt to such requirements in real time, and nor can they mitigate or prevent further abuse [4]. By the time a permissions-related issue is discovered, more damage may have been done, adding to the potential financial, operational and reputational burdens of rectifying it. Furthermore, organisations tend to be reactive rather than proactive in deploying Cyber Security mechanisms, even in the face of reports such as the 2019 Verizon Data Breach Investigation Report [5] which divulged that 34% of breaches involved

insider action (increasing to over 50% in the Healthcare and Education sectors).

Whilst work has been undertaken in the space of adapting access control decisions dynamically (e.g. to allow more access permissions with increased positive experiential feedback based on the user’s evolving risk profile [6]; and in allowing access in context via use of a risk-score for users accessing IoT devices [7]), research remains emergent (e.g. [8], [9], [10]) in the way of dynamically adapting the access control *policies* themselves, and to addressing insider threat in general.

Our work builds upon the self-adaptive RBAC (saRBAC) approach [10] by applying anomaly detection methods drawn from the field of statistical analysis and outlier detection before deriving a set of adaptive RBAC policy rules as appropriate. Outlier detection is relevant in the scope of anomaly detection since outliers, like anomalies, are data which deviate from either some expected norm or from the remainder of a set, although the treatment of the anomalies once detected may differ (in statistical outlier detection, the aim is to either remove outliers or correct for them before proceeding with further analysis, whereas in Anomaly Detection, the aim is to find the anomalies and decide whether to take evasive action to protect a network or system).

The methods applied include scoring methods, cluster analyses and statistical hypothesis testing to determine whether user behaviour can be described as unusual by comparison to some expected norm, and therefore an anomaly.

The proposed methods were evaluated for two insider threat scenarios: One investigation pertaining to the Customer as a threat (representing a potential denial of service attack), and the other pertaining to the IT Support Person as a Threat (representing system abuse and potential employee fraud). The evaluation was performed on synthesised logs of an IT helpdesk process and results showed that outlier detection methods can be appropriately applied to the saRBAC model as an alternative to modelling business processes as Discrete-Time Markov Chains (DTMCs) and using parametric model checking.

The rest of this paper is organised as follows: Section 2 presents background information on the statistical methods applied including z-scores, Tukey’s method, cluster analysis, and hypothesis testing. Section 3 outlines the steps of the

approach to anomaly detection. Section 4 introduces the business process considered for evaluating the statistical methods for outlier detection and presents the results from applying the various statistical outlier detection methods on the case study, together with the formalised self-adaption rules. Section 5 presents an overview of existing work in the field of anomaly detection within the context of access control. Finally, Section 6 concludes the paper with a summary and recommendations for further work.

2. PRELIMINARIES

2.1. Statistical Hypothesis Testing

When we observe some measurement (such as a mean, a difference between groups, the effect of a treatment) we are only observing a single outcome from one sample. Had we taken a different sample, our results would likely be different. Sample parameters are thus estimates of some underlying true population parameter which, generally, we do not know the value of. That said, we can hypothesise what the true values are and then conduct a hypothesis test. A hypothesis test allows us to choose between competing hypotheses about what the true population value is, for example one hypothesis may claim that the average time taken to complete a task is 10 minutes, whereas another may claim that it is significantly higher than 10 minutes.

When conducting a hypothesis test, the hypothesis to be tested is termed the *null hypothesis*. The null is assumed to be correct unless there is sufficient evidence to the contrary. The competing hypotheses are termed *alternative hypotheses*, and these act to challenge the null. When conducting a hypothesis test, a significance level, α , must be chosen. This is the probability of making a type I error (that is, rejecting the null when it is in fact correct). There will always be a chance of making such an error, but we select α to be sufficiently small (i.e. we accept *a priori* a small chance that we will make such an error).

The tests are performed using suitable statistical software and a p-value reported. The p-value gives us the probability of making a type I error given the data we have seen. This can be compared to α in order to decide whether or not our null hypothesis is likely to be correct: A very small p-value (smaller than α) indicates that we are unlikely to see data so extreme under the null hypothesis, and so we are wise to reject it.

2.2. Statistical Property-Based Outlier Detection

Originally proposed for detection of outliers by Tukey [11], the following methods are appropriate when anomaly detection is required for unsupervised data. The rationale behind these methods is that “normal” observations fit into some underlying pattern, which can be described by a statistical measure (e.g. a mean, median, or statistical distribution), and so we can assess (informally and formally) whether an individual observation belongs in the set by measuring how different it is to the rest.

Z-Scores. A Z-Score (or standard score) describes a point relative to the mean and standard deviation of a set of points. The Z-Score is found by subtracting the mean and dividing by the standard deviation. The idea is that having centred and rescaled the data in this way, anything too far from zero can be considered anomalous. Often the threshold is anything greater than ± 3 (or values very close to 3). The rationale for this is based on an assumption that the data being measured has an underlying normal distribution, and that any data outside 3 standard deviations of the mean is “extreme” (about 99.7% of Normally distributed data lies within 3 standard deviations of the mean).

Tukey’s IQR Method. This method looks at the data as it is ranked, and determines outliers/ anomalies relative to distance from the median (50th percentile). The Interquartile range (IQR) is calculated as the distance between the 75th percentile (Quartile 3) and the 25th percentile (Quartile 1). This is then multiplied by 1.5. Points are considered to be extreme if they are above $1.5 \times \text{IQR}$ above the upper quartile, or $1.5 \times \text{IQR}$ below the lower quartile.

Modified Z-Score. The Z-Score cutoff is guided by an underlying assumption of normality in the data, an assumption which may be incorrect. As such, the identified outliers may be due to non-normality of the data rather than them being true anomalies. As a way to accommodate for this, a modified z-score is proposed by Iglewicz and Hoaglin [12]. This score is defined as:

$$M_i = \frac{0.6745(Y_i - Y_{\text{median}})}{\text{MAD}}$$

$$\text{MAD} = \text{median}(|Y_i - Y_{\text{median}}|)$$

where MAD is the median absolute deviation. Since the median is the positional “middle” value of the data, it is not affected by the extremes and is therefore considered to be a more robust measure of central tendency. Values greater than 3.5 are considered to be extreme.

2.3. Clustering-Based Outlier Detection

The aim of cluster analysis is to explore data and attempt to divide it into groups (clusters) which are distinct from one another. Clusters are defined by some distance measure, and the distance between points within a cluster is smaller than that of any points outside of the cluster. The most commonly used distance measure is the Euclidean distance $d_{ij} = \sqrt{(x_{i1}-x_{j1})^2 + (x_{i2}-x_{j2})^2 + \dots + (x_{ik}-x_{jk})^2}$. In two dimensions this is equivalent to calculating the shortest distance between two points. There are several clustering algorithms available, and we consider Hierarchical clustering algorithms only: These methods are useful when exploring data and the number of potential clusters may be unknown in advance.

3. APPROACH

To undertake an investigation of this nature, the business process of interest needs to be supported by an RBAC-based IT system. Logs of the business process must be available, which capture the activities undertaken by individual users, and the time at which these activities took place. The logs must have accumulated a sufficient volume of data for subsequent analysis to take place.

The types of insider threat that the business may face will need to be considered and formulated in terms of an anomalous activity, which can be expected to be detected if present. This needs to be something that is captured in the logs, and would typically take the form of an activity taking a different amount of time to complete, or a different volume of a certain activity being undertaken for an individual, either versus their peers, or versus some pre-defined status quo.

Given the insider-threat scenario, the statistical methods outlined in Section 2 are applied to the log data, having first processed the logs using appropriate statistical software. Hypothesis testing is used to test for high level differences between users, followed by the outlier detection methods and cluster analyses where evidence of differences occur. Having detected outliers, access control policies can be adapted to take the observed anomalies into account.

The problem addressed by this project is illustrated by the high level workflow shown in Figure 1, asterisked (*) elements of which show the parts of the approach that have been developed as part of this research. The top segment of this figure demonstrates the behaviours of a system being captured via system logs whilst it operates under prior, “normal” conditions. Having established the model of normal behaviour (which may also incorporate information obtained from directly observing the business process or discussing with subject matter experts within the business as well as assessing the system logs generated by the process) this model of expected normal behaviour is compared to events witnessed during runtime operation. The bottom segment of Figure 1 shows that during runtime operation, the expected behaviours of the system can be compared to actual events as they occur. These events may be uninteresting (from an anomaly detection perspective), or the comparison may return data which goes on to be classified as anomalous. Rules pertaining to the behaviour exhibited can be devised which then inform whether to adapt RBAC permissions.

4. EVALUATION

The approach taken is illustrated and evaluated using a simplified ticketing system for the IT helpdesk of US-based strategic consulting and management services provider, Virtual Inc. IT related issues are logged with IT support by either a Customer or IT Support worker raising a ticket. A Customer is defined as an individual user who requires an IT service, and IT Support workers are the employees responsible for handling tickets. The system specification

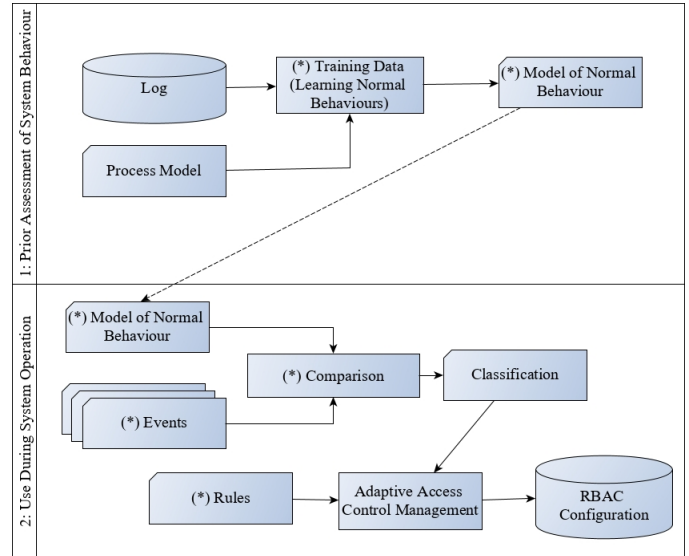


Figure 1. Generic Approach and Scope of the Project

has been simplified for the purposes of this project and is described as follows:

Process Description. The ticket support process begins with either an “individual” (i.e. a Customer) opening a ticket, or an IT support worker opening a ticket on the Customer’s behalf. At this point, the ticket’s state in the system is termed as “Created”.

Open tickets can only be closed by IT Support staff (or a built-in timeout process which is activated after seven days of no activity at key stages in the process). Support staff are assumed to be equally capable in terms of skills and experience, and so tickets are allocated to support staff randomly as they are created. Furthermore, they are assumed to be allocated on-demand i.e. on a first-come first-served basis (i.e. there is no prioritisation of jobs either due to their expected workload requirement, severity of issue, or the channel through which they were received).

Once an investigator for a ticket has been allocated, the ticket state becomes “Assigned”. At this point an investigation begins with the aim of resolving the issue. If there is not enough information to resolve the issue, then IT Support will contact the Customer for more information. If there is no response after 7 days, the ticket is closed, and a new ticket will need to be raised if the issue persists. If the customer responds with more information, then the investigation continues by the same IT Support worker.

If no further information is required, the support worker will resolve the issue and the ticket’s state will be changed to Resolved. At this point, the customer has 7 days to contest and re-open the ticket (which has the effect of sending the ticket back to the start of the process where it will be allocated to a member of IT Support afresh). If seven days pass without a request to re-open the ticket, the ticket is marked as closed.

A ticket can be closed at any state by IT Support, provided a comment is given. The intention of this is to allow for situations where a ticket may need to be cancelled at any point in the process (e.g. issues found to have been raised in error, customers leaving the company mid-resolution, or the issue being resolved by the customer first).

This process is depicted in the flowchart in Figure 2.

Results. This section summarises the main results obtained from applying the methods given in Section 2. To evaluate the statistical methods and their suitability for anomaly detection, two separate insider threat scenarios were injected into the system logs: the first scenario is that of a Customer opening a high volume of tickets compared to others. Under this scenario, the customer is expensive in terms of resourcing, and such behaviour therefore represents a denial of service attack. The second scenario is focused on IT Support behaviour and considers a high volume of tickets opened and then closed down in a short time by one employee. This scenario represents system (and privilege) abuse and potentially employee fraud (e.g. if the employee is creating fake jobs to boost performance metrics, which may then be linked to performance related pay).

By assessing the contaminated log files (“Events”) and comparing them to the model of normal behaviour (as per Figure 1), we are able to use statistical methods to determine whether Customers or IT Support pose any threats to the process, classify them as anomalous, and ultimately attempt to determine whether they need to have their access control permissions to this process modified or revoked.

4.1. Scenario 1

Scenario Construction. In the simulated logs, under normal operating conditions, the arrival rate of tickets into the support system is modelled by the Poisson distribution with a mean rate of 288000 seconds, equivalent to each person opening a ticket once every two weeks on average. An attack Event is created by injecting six malicious users into the log simulation. These users have increased ticket opening rates as follows: two users with an opening rate equivalent to opening one ticket per week, two users with an opening rate equivalent to opening two tickets per week, and two users with an opening rate equivalent to opening one ticket per day.

The aim is to apply statistical measures to determine whether any of these users can be detected as anomalous.

The process is observed over a period of 26 working weeks (roughly six months) and the number of tickets opened by each customer is observed. Under this scenario we would expect the threat actors to have an unusually high number of tickets on a rolling basis, as well as a higher average rate of opening tickets than a regular customer. The analysis was undertaken in SAS and SPSS.

Initial Exploratory Analysis. Initial visual assessment of the number of tickets opened per person revealed that there were a number of customers whose number of tickets

opened appeared to be unlike the others in the set (Figure 3). The overall descriptive statistics further demonstrated that there was a greater spread in the number of tickets opened in the Threat Scenario (Table 1). The median and mode remain largely unaffected by these potential anomalies (as would be expected since such measures are not influenced by extreme values), however the mean number of tickets opened is increased by an extra 7 tickets *per person* over the period of observation. It is clear however from the box plot that most people are not opening an extra 7 tickets each - they are still opening around 13, and so we proceeded to use analytical methods to try to identify the anomalous cases.

Table 1. NUMBER OF TICKETS OPENED PER PERSON

Statistic	Scenario 1	Normal Operating Conditions
Mean	20.06	13.30
Median	13.00	13.00
Mode	13.00	13.00
Standard Deviation	23.97	0.93
Range	118.00	4.00
Interquartile Range	1.00	1.00
Skew	4.13	0.46

Statistical Analysis. Initial formal analysis consisted of conducting a statistical hypothesis test for a difference between the two groups before applying methods to determine where the differences lie. Owing to the non-Gaussian nature of the underlying data, non-parametric testing was undertaken: The Kolmogorov-Smirnov (KS) test and Moses Test of Extreme Reactions were used to determine a) whether there appeared to be a difference in the overall distribution of the groups; b) whether there appeared to be extreme values (i.e. anomalies) in the group with injected threats. For the KS test, the formal null hypothesis is that the distributions of the “number of tickets opened” data for the Normal Conditions Simulation and Scenario 1 Simulation are the same (vs. an alternative hypothesis that they are not the same); for the Moses test the formal null hypothesis is that Extreme Values are equally likely to come from both populations (vs. an alternative hypothesis that extreme values are more likely to come from the Scenario 1 logs). The full tests were performed in SPSS at a significance level of 0.05 and the results are given in Columns 1 and 2 of Table 2. The KS test did not detect a difference in the distribution of the two groups due to its lack of sensitivity in the tails, however the Moses test confirmed that there was strong evidence that extreme values were present in the Scenario 1 log.

Statistical Property Based Analysis. Having confirmed that anomalies were likely to be present, Z-Scores, modified Z-Scores, and values for Tukey’s IQR method were calculated, and the results summarised in Table 3. This table

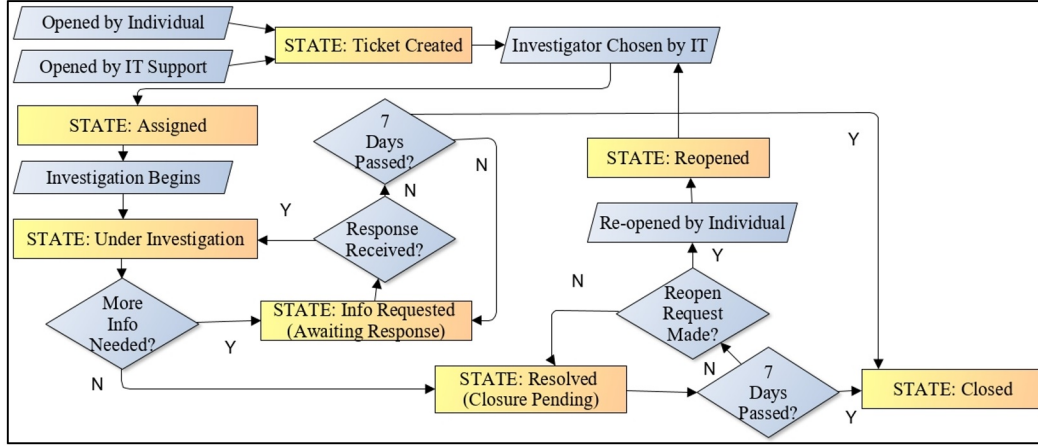


Figure 2. Flowchart: Simplified Virtual Inc. IT Support Process

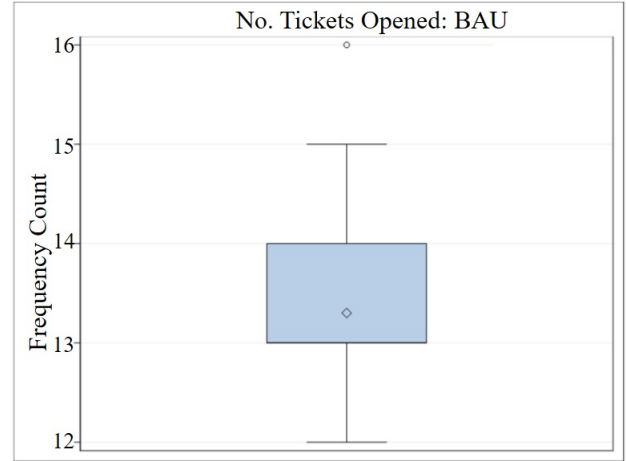
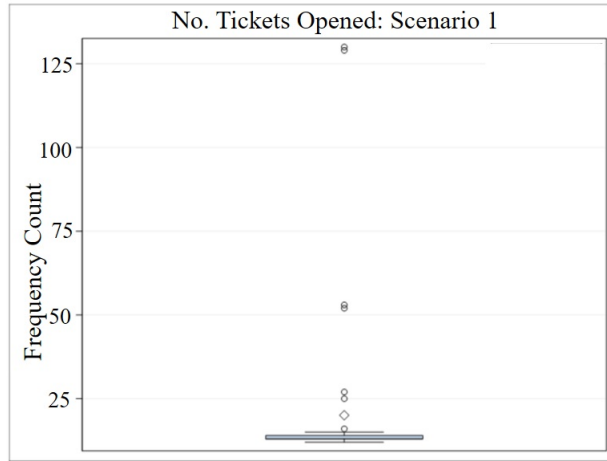


Figure 3. Boxplots of Number of Tickets Opened Per Person (Left: Scenario 1; Right: Normal Operating Conditions)

Table 2. STATISTICAL TESTS

	K-S Test	Moses Test	ANOVA
Null Hypothesis H_0	The distribution of "Number of Tickets Opened" is the same for both groups	Extreme values are equally likely to come from both groups	No difference between the support Staff
Alt. Hypothesis H_1	The distributions differ	Extreme values are more likely in the Event group (Injected Logs)	There is a difference between 2 or more IT Support Staff
Sig. Level α	0.05	0.05	0.05
P-Value	0.864	0.02	<0.0001
Result	Fail to reject H_0	Reject H_0	Reject H_0

gives the Employee ID together with whether the employee's behaviour was identified as anomalous. The modified Z

score out-performed the regular Z-Score (which flagged one "normal" customer as potentially anomalous due to the Z-Score being very close to 3. Tukey's IQR method identified this "borderline" customer as a clear anomaly when it was in fact a regular customer. The modified Z-Score identified only the true anomalous cases as anomalies. The false positive rate for the IQR and Z-Score method was $1/44 = 2.27\%$ (if borderline cases are included for Z-Score); and for the modified Z-Score: 0%.

Although the false positive rate is encouraging, a sensitivity analysis demonstrated that the Modified Z-Score, whilst being superior in terms of false positives for the simulation, does not register behaviour as anomalous until there has been at least a 42% increase (or decrease) in the number of tickets opened. This is equivalent to an additional 18.5 tickets over the 26 week period. With this in mind, management would need to consider whether the modified Z-score is sensitive enough at the upper extreme in the context of the helpdesk's work volumes.

Table 3. ANOMALY DETECTION RESULTS: CASES MARKED AS ANOMALOUS

Employee ID	Z-Score	Modified Z-Score	Tukey's IQR	False Positive
25	x		x	Y
45	x	x	x	N
46	x	x	x	N
47	x	x	x	N
48	x	x	x	N
49	x	x	x	N
50	x	x	x	N

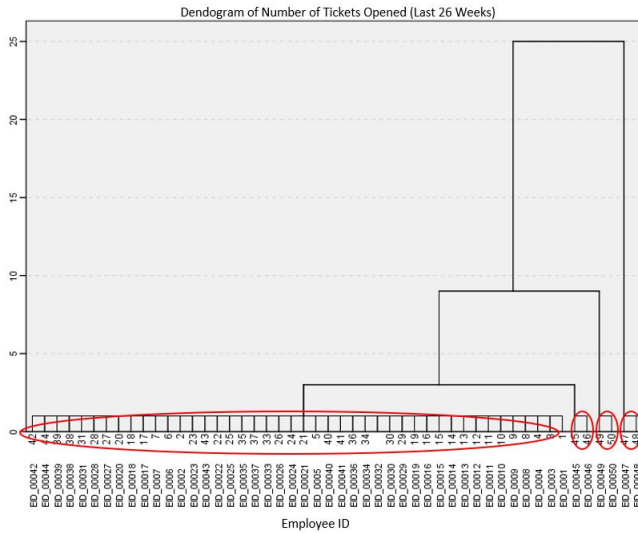


Figure 4. Dendrogram: Hierarchical Clustering for Scenario 1 Simulation (with Euclidean Distance and average linking)

Cluster Analysis. The cluster analysis was performed in SPSS using a distance measure of Euclidean Distance with average linkage. The analysis correctly identified one clear large cluster (employee ID's 001 to 0044) with a further one, two or three small clusters each containing two employees, depending on where the dendrogram is cut. No cases were misclassified, and the cluster analysis demonstrated strong ability to find small clusters for each of the three injected threat types.

4.2. Scenario 2

Scenario Construction. In the simulated logs, under normal operating conditions, the time taken to investigate a ticket (i.e. work on it) is modelled by a normal distribution with a mean of 3600 seconds, equivalent to one hour per ticket, and a standard deviation of 900 seconds (15 minutes). Furthermore, tickets are opened at a rate of once a fortnight per customer, either by a customer themselves or by a member of IT support staff on behalf of a customer. In the

attack scenario, one member of support staff's behaviour is modified so that they behave as normal for the majority of the time, but are allocated an additional number of tickets which are then closed down much faster than would be expected. The simulation parameters affected are: a) The Poisson assumption (ticket opening frequency). This was kept as Po(288000) for the majority of the time, but an additional number of tickets were set to be opened at a rate of 1 per week (i.e. Po(144000)); b) The Normal Distribution assumption (time to undertake an investigation). This was modified from $N(3600, 900^2)$ to $N(300, 60^2)$ i.e. open on average for 5 minutes with a standard deviation of one minute, for the additional one ticket per week.

The change was applied to one of the three support staff.

Initial Exploratory Analysis. The assumptions for the process under normal operating conditions tell us what the average time to work on a ticket should be (3600s) on observation of the distribution of average time spent on a ticket per person in the logs (Figure 5), it was clear that Support Person 53 was working on more tickets then their peers that have a much shorter lifespan (there is a density of observations around 150s).

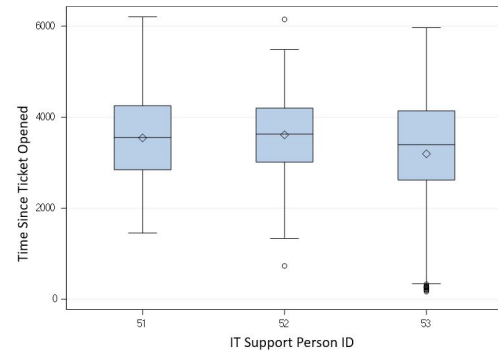


Figure 5. Boxplots of time spent working on tickets by each Support Person

One-Way Analysis of Variance (ANOVA). The next stage of the analysis was to test whether this density was significant enough to be flagged as anomalous using Analysis of Variance (ANOVA), together with Tukey's Post Hoc Comparisons. The ANOVA assesses whether there are statistically significant differences between the three IT Support staff, and Tukey's comparisons demonstrate where the differences lie. The ANOVA test is given in Column 3 of Table 2, and shows that there was a statistically significant difference in the time spent working on a ticket between the IT Support staff.

The ANOVA test can tell us whether a difference between IT Support staff exists but it cannot tell us which support person is different from the others. Tukey's Honest Significant Difference (HSD) Test is a commonly applied post-hoc comparison on each pair of means. The comparison calculates the Studentised range for each pair of means and returns a set of confidence intervals for the mean difference,

Table 4. TUKEY’S HSD COMPARISONS: SCENARIO 2

Comparisons significant at the 0.05 level are indicated by ***.			
Ticket Support Person Comparison	Difference Between Means	Simultaneous 95% Confidence Limits	
52 - 51	67.04	-166.66	300.74
52 - 53	417.25	180.33	654.18 ***
51 - 52	-67.04	-300.74	166.66
51 - 53	350.21	116.77	583.65 ***
53 - 52	-417.25	-654.18	-180.33 ***
53 - 51	-350.21	-583.65	-116.77 ***

for each pairwise comparison. Provided the confidence intervals for the mean difference contains 0, we conclude there is no difference between those two groups. The results are given in Table 4 and demonstrate that there is no significant difference between IT Support Persons 51 and 52, but there is a significant difference between persons 51 and 53, and 52 and 53. From this we can conclude that Person 53 is behaving anomalously with regard to the number of tickets opened and closed, and the time which is spent upon those tickets, and that management investigation appears to be warranted.

4.3. Self-Adaption Policies

The results in Sections 4.1-4.2 can be used to inform a set of rules, which in turn inform RBAC configuration adaptively under the saRBAC approach given in [10]. These rules are informally:

- Policy₁: A customer in the test set who creates more tickets than expected compared to everyone in the reference (BAU) set, as determined by the statistical or cluster analyses, should not be allowed to open new tickets.
- Policy₂: An IT Support worker whose time spent working on tickets is significantly lower on average than their co-workers, as determined by ANOVA and Tukey’s tests, should not be allowed to open new tickets on behalf of users directly. Their tickets should be assigned by a Supervisor(*).

(*) Note, Policy₂ requires the creation of a new role, $R_3 = Supervisor \subseteq Support$.

Following the definitions in [10] these self-adaption policies may be expanded upon and formalised; it is envisaged that these policies would be used by the Adaptive Access Control Manager displayed in Figure 1, which contains information about the the users being analysed, the log traces, and information about the company’s RBAC policy. Suitably derived postconditions are then used to update the RBAC configuration as required, when anomalous behaviour is detected.

5. COMPARISON OF EXISTING WORK:

Whilst work has been undertaken in the space of adapting access control decisions dynamically (e.g. to allow more access permissions with increased positive experiential feedback, based on the user’s evolving risk profile as in [6]; and in allowing access in context via use of a risk-score for users accessing Internet of Things (IoT) devices [7]), research remains emergent in the way of dynamically adapting the access control *policies* themselves, and to addressing insider threat in general. Recent approaches are summarised in Table 5, which gives the merits and limitations of the self-adaptive access control mechanisms in the literature. It demonstrates that research is in the early stages at present, and that (with the exception of [8], which gives a generic framework) current methods are quite restrictive in that they apply only to a specific domain.

This approach is unique in that it uses statistical techniques to test for differences between users, and is particularly suited to problems where we are looking to determine whether there are differences between two or more groups (such as live data to training data), or that there are differences in the behaviour of one individual compared to a larger set, without the need to build abstract parametric models. Instead, logs of business processes can be scrutinised directly for evidence of deviations from normality.

6. CONCLUSIONS

One cannot rely solely on access control mechanisms to protect information assets: even if a subject is granted access under the principle of least privilege [14], their role may evolve, or their capabilities may not continue to be well aligned to the privileges set. In such a situation, an individual may deviate from what is expected, but by measuring and monitoring live system behaviour, we can capture environmental information and learn from it.

By applying adaptive measures, an appropriate response can be formulated and applied in real time, however it is not without risk: an appropriate degree of accuracy must be chosen to balance the false positives (and false negatives), but false positive rate alone cannot be relied upon, and the analytical method selected must be well understood in terms of its strengths and weaknesses. In this paper we introduced an approach based on statistical analysis: first by looking for evidence of differences between individuals (or between known “normal” behaviour and runtime behaviour) which could indicate an anomaly, and then by looking into where those differences lay in order to identify specific individuals.

To evaluate the new approach, simulated logs were used, however the methods could equally apply to real data. This would be a logical next step, along with automating some of the (very labour intensive) manual parts of the analysis. Future work could additionally extend to: a) improve the simulation to more closely reflect the business process; b) consider and evaluate alternative analyses (e.g. different hypothesis tests, or clustering algorithms); c) consider other scenarios and devise a complete set of statistical analyses

Table 5. COMPARISON OF RECENT DEVELOPMENTS IN SELF ADAPTIVE ACCESS CONTROL

Paper	Application Domain	Method	Strengths	Limitations
[8]	NA: Provides a Framework	Cost-function to identify anomalous behaviour and adapt permissions to those which cause least cost to the organisation	Generic - applicable to wide range of platforms and scenarios; no need to adopt new access control models; Adaptive: Suitable in RBAC and ABAC environments	Large administrative overhead
[9]	Cloud (OpenStack Keystone)	Log querying within MAPE-k Framework to identify unusual activity using an "autonomic controller"	Incorporates self-adaptation into OpenStack access control mechanisms	Narrow focus on what insider threats can be handled; Logs alone cannot detect threats; Considers RBAC only (not ABAC)
[13]	Cloud (Between Service Providers)	Risk score based on how trusted the CSP is and whether they've done anything anomalous before	Approach is intuitive and simple to understand; Adaptive - can respond to new users in emergency situations	Reputation score is subjective and open to abuse/manipulation; Single threat vector ("other CSP") considered; Continuous monitoring risk score is computationally intensive
[10]	Offline (Business processes)	Calculates Markovian model properties and uses confidence intervals to assess whether cases are anomalous	Applicable to any process where a UML diagram is available; large number of potential threats considered; Logs capture all necessary info regarding threats	Restricted to Markov model system representation; Model could get complex if business processes overlap; Applied to RBAC only (not ABAC)

which would be applicable for more types of insider threat, considering additional, potentially dynamic, methods such as time series analysis or statistical process control; and d) build a prototype to see how the self-adaption performed. The original saRBAC approach undertakes this analysis however it would be a highly manual process at present, and it is beyond the scope of this project.

ACKNOWLEDGMENT

I would like to thank Virtual Inc. for their permission to base the case study used to evaluate my work on their ticketing support system, and I would further like to express my gratitude for the guidance and reviews provided by my supervisor, Dr. Radu Calinescu, whilst undertaking this project.

References

- [1] D. E. Denning, "An Intrusion-Detection model," *IEEE Trans. Software Eng.*, vol. SE-13, no. 2, pp. 222–232, Feb. 1987.
- [2] K. Wang and S. J. Stolfo, "Anomalous Payload-Based network intrusion detection," in *Recent Advances in Intrusion Detection*. Springer Berlin Heidelberg, 2004, pp. 203–222.
- [3] American National Standards Institute, "INCITS 359-2004. american national standard for information technology - role based access control," 2004.
- [4] C. Bailey, D. W. Chadwick, and R. de Lemos, "Self-adaptive federated authorization infrastructures," *J. Comput. System Sci.*, vol. 80, no. 5, pp. 935–952, Aug. 2014.
- [5] Verizon, "2019 data breach investigations report," <https://enterprise.verizon.com/resources/reports/2019-data-breach-investigations-report.pdf>, May 2019, accessed: 2019-10-5.
- [6] R. A. Shaikh, K. Adi, and L. Logrippo, "Dynamic risk-based decision methods for access control systems," *Comput. Secur.*, vol. 31, no. 4, pp. 447–464, Jun. 2012.
- [7] H. Ouechtati, N. Ben Azzouna, and L. Ben Said, "Towards a self-adaptive access control middleware for the internet of things," in *2018 International Conference on Information Networking (ICOIN)*, Jan. 2018, pp. 545–550.
- [8] C. Bailey, D. W. Chadwick, and R. d. Lemos, "Self-Adaptive authorization framework for policy based RBAC/ABAC models," in *2011 IEEE Ninth International Conference on Dependable, Autonomic and Secure Computing*, Dec. 2011, pp. 37–44.
- [9] C. E. Da Silva, T. Diniz, N. Cacho, and R. d. Lemos, "Self-adaptive authorisation in OpenStack cloud platform," *Journal of Internet Services and Applications*, vol. 9, no. 1, p. 19, Sep. 2018.
- [10] C. E. da Silva, J. D. S. da Silva, C. Paterson, and R. Calinescu, "Self-adaptive role-based access control for business processes," in *Proceedings of the 12th International Symposium on Software Engineering for Adaptive and Self-Managing Systems*. IEEE Press, 2017, pp. 193–203.
- [11] J. W. Tukey, *Exploratory Data Analysis*, 01st ed. Addison-Wesley Publishing Company, Jan. 1977.
- [12] B. Iglewicz and D. Hoaglin, "Volume 16: how to detect and handle outliers," *The ASQC basic references in quality control: statistical techniques*, vol. 16, 1993.
- [13] A. A. Malik, H. Anwar, and M. A. Shibli, "Self-adaptive access control delegation in cloud computing," in *2016 17th IEEE/ACIS International Conference on Software Engineering, Artificial Intelligence, Networking and Parallel/Distributed Computing (SNPD)*. ieeexplore.ieee.org, May 2016, pp. 169–176.
- [14] F. B. Schneider, "Least privilege and more [computer security]," *IEEE Security Privacy*, vol. 1, no. 5, pp. 55–59, Sep. 2003.